

depscan-reports/ — human-readable pipeline output (for review)

Professional PDF reports produced by the Dependency & Supply-Chain pipeline. Review these in the PR.

File	Stage	What it shows
CVE-Report.pdf	Stage 1 — Dependency scan	Known-vulnerable dependencies, CVE list with CVSS/severity, fix versions, supply-chain alerts
Risk-Scoring-Report.pdf	Stage 2 — Risk scoring	Ranked remediation backlog ($\text{risk} = 0.5 \cdot \text{CVE} + 0.3 \cdot \text{exposure} + 0.2 \cdot \text{criticality}$), priorities
Remediation-Report.md	Stage 3 — Auto-remediation	Consolidated fix table (old → new versions, CVEs cleared), changelog highlights, build/re-scan verification
Audit-Trail-Report.pdf	Stage 5 — Audit trail	Health score + grade, remediation activity, gate verdict, projected post-fix score

Each `.pdf` has a matching `.md` (diff-friendly source); the machine-readable `*.json` reports live at the repo root. PDFs are generated from the Markdown + a shared stylesheet via `md-to-pdf` (headless Chromium) — locally or in CI. See the plugin's `templates/report/RENDER.md`.